

RIMZENBERG AWS HANDOVER NOTES

Written by: Dev Okonkwo — Senior Cloud Engineer (leaving end of Sprint Week 2)

For: Incoming Junior Cloud Solutions Architect

Last updated: 17 February 2025 (incomplete — ran out of time)

⚠ **These notes are deliberately incomplete.** I only had time to document what I set up initially — anything from the last 6 months is undocumented. There's stuff in here I should have fixed and didn't. Priya knows. Good luck.

STAGE 1 — WHAT WE BUILT (ORIGINAL MIGRATION, 18 MONTHS AGO)

Core infrastructure

We migrated from an on-premise VMware cluster to AWS eu-west-2 (London) in August 2023. The migration was done in 6 weeks — the timeline was too tight but the business insisted. I moved everything like-for-like (lift and shift), intending to re-architect properly later. That later never happened.

What's running: - 2× EC2 t3.medium instances (web tier) — `rimzenberg-web-01` and `rimzenberg-web-02` - 1× RDS MySQL db.t3.medium (production database) — `rimzenberg-rds-prod` - 1× Application Load Balancer — `rimzenberg-alb-prod` - S3 bucket for static assets — `rimzenberg-static-assets` - S3 bucket for order receipts — `rimzenberg-order-receipts` - Route 53 hosted zone — `rimzenberg.co.uk` - CloudTrail enabled (basic — logs to S3)

Region: eu-west-2 only. No secondary region. No Multi-AZ on RDS (I tried to get budget for it — didn't get approved in time).

Networking

Everything runs in a single VPC (`rimzenberg-vpc-prod`). I didn't have time to set up proper subnet segmentation — all resources are in public subnets. I know this is wrong. The RDS instance being in a public subnet is the thing I'm most uncomfortable leaving you with. See the environment audit CSV — it's flagged as `PUB-RDS`.

IAM

I gave the EC2 roles `AdministratorAccess` to unblock deployments quickly during the migration. **This needs fixing urgently.** Farah's account has `PowerUserAccess` — probably too broad but I didn't want to block her. Marcus has `ReadOnly` which is fine.

⚠ **CHECK THIS:** My own IAM user (`dev.okonkwo`) has `AdministratorAccess` with both console and programmatic access keys active. Priya said she'd sort the offboarding but make sure my access is revoked when I leave. The access key is in the `.env` file in the old Lambda POC folder — `NOT DOCUMENTED` where that is now.

STAGE 2 — THE LOAD BALANCER AND HEALTH CHECK ISSUE

ALB setup

The ALB is single-AZ (eu-west-2a). I know it should be multi-AZ — same budget issue as the RDS Multi-AZ problem.

The health check thing — READ THIS CAREFULLY

There is a known issue with the ALB health checks. The security group on the EC2 instances (`rimzenberg-web-01` and `rimzenberg-web-02`) has an outbound rule that **blocks the health check port** in certain conditions. I fixed it twice but it kept reverting — I suspect a CFN stack drift issue but I didn't track it down.

⚠ **NOT DOCUMENTED:** Why the SG rule keeps reverting. There is a CloudFormation stack (`rimzenberg-cfn-sg-01`) that I think is overwriting the manual fix. **CHECK THIS** — the stack might be drifted.

This is the `SG-HC-BLOCK` code in the environment audit. It is part of why the Black Friday outage was so bad — the health check block meant the ALB couldn't route traffic away from the overloaded instance even when the second instance was available. **The traffic spike alone did not cause the 4-hour outage. The health check block combined with the RDS connection pool exhaustion is what turned a spike into a full P1.**

⚠ **Note from Dev:** If you look at the incident log and only look at the `traffic_spike_pct` column, it will look like traffic spikes are the main problem. They are not. The P1 incidents with the longest duration are almost always the ones where `sg_health_check_blocked = TRUE` **and** `db_conn_pool_pct` is above 95%. Look at all three columns together for INC-024. That's the real story.

STAGE 3 — THE RDS CONNECTION POOL PROBLEM

What's happening

The RDS instance (`rimzenberg-rds-prod`) is a `db.t3.medium` which has a `max_connections` limit of approximately 150. During any significant traffic spike, the order processing code opens a new DB connection per request and doesn't close them cleanly. I've seen the pool hit 100% (effectively blocking all new connections) at least six times since the migration.

⚠ **NOT DOCUMENTED:** The exact connection string in the order processing application. It's somewhere in the EC2 instance's environment variables. I think it's also hardcoded in one of the older Lambda POC scripts — `DEPRECATED?`

Why the RDS is in a public subnet

I needed direct access during the migration for debugging and I just never moved it. The security group `SG_inbound_0.0.0.0/0:3306` is wrong and I know it. Marcus flagged it in October. I didn't have cycles to fix it.

⚠ **COMPLIANCE RISK:** Customer PII (names, email addresses, order history) is stored in this RDS instance. The public subnet exposure + broad SG inbound rule is a UK GDPR Article 32 issue and an NCSC Cloud Security Principle 3 failure. Marcus Webb will flag this at the Week 6 review if it's not fixed.

STAGE 4 ONWARDS — NOT DOCUMENTED

I ran out of time to document: - The Auto Scaling Group (there isn't one — this is `N0-ASG` in the environment audit) - The CloudWatch setup (there isn't one — this is `N0-CW` in the environment audit) - The Lambda POC for order processing (built in March 2025, not deployed to prod, files in an S3 bucket somewhere — `NOT DOCUMENTED`) - The backup configuration (RDS automated snapshots set to 7 days — that's it) - The CFN stack inventory (at least 3 stacks, one of which is drifted — `CHECK THIS`) - The Route 53 health check configuration (there are none — `R53-N0-HC` in the audit)

OPEN QUESTIONS (unanswered at time of handover)

1. Where is the Lambda POC code for the order processing migration? I saved it to an S3 bucket in March 2025 but didn't push to GitHub. `NOT DOCUMENTED`
2. Is the CFN stack `rimzenberg-cfn-sg-01` causing the SG health check rule to keep reverting? `CHECK THIS`
3. What is the monthly cost breakdown per workload? Finance is asking. I don't know — no Cost Explorer tags set up. `NOT DOCUMENTED`
4. Has Marcus confirmed which NCSC principles we're failing? I know about Principle 3 (network protection) and Principle 9 (identity and access). `CHECK THIS` — there may be others
5. What happens to my IAM access keys after I leave? `NOT DOCUMENTED` — Priya to confirm

CONTACTS

- **Priya Nakamura** (Engineering Manager) — your line manager, signs off all phases
- **Farah Hussain** (Head of Operations) — asks cost and uptime questions
- **Marcus Webb** (Head of Security & Compliance / DPO) — the NCSC/GDPR constraint
- **Me (Dev Okonkwo)** — available until end of Sprint Week 2 on Slack, then gone

